

잠긴 플랜두씨 다이어리

내 기록을 나만 보게 만들기 — 가입·로그인·서버 세션·사용자별 자료 차단

- 과제 6 다이어리를 지우지 않고 같은 저장소·배포·DB에서 이어 개발
- bcrypt(cost 12) 비밀번호 · DB에 SHA-256만 남는 폐기 가능한 서버 세션
- 세션에서만 사용자를 정하고, 남의 자료는 양방향 모두 404
- 5일 실제 사용으로 계획 규칙 변경 전후의 시간 오차율 비교

<https://plan-do-see-diary.vercel.app>

2026.09.03

제출 결과물과 고정 소스

심사자가 계정 없이 열 수 있는 공개 주소와, 그 시점의 소스를 가리키는 고정 URL.

28건

자동 검사 통과

0건

타 계정 자료 유출

0건

비밀값 노출 (로컬·Git 이력)

404

남의 자료 요청 응답

주소

- 공개 결과물 — <https://plan-do-see-diary.vercel.app>
- GitHub 저장소 — <https://github.com/stulss/plan-do-see-diary>
- 인증 구현 설명서 — docs/과제7/인증_구현_설명서.md
- 검증 안내서 — docs/과제7/검증안내서.md · AI 3줄 — docs/과제7/AI_3줄.md
- 5일 사용 기록 — docs/과제7/5일_사용기록.md · 증거 색인 — docs/과제7/evidence/README.md

과제 6과의 관계

과제 6의 계획·할 일·실행 기록·돌아보기 구조와 기존 자료를 삭제하지 않고 같은 저장소·Vercel 프로젝트·Supabase PostgreSQL 에서 이어 개발했다.
과제 6 고정 commit 356a460 이 main 이력의 조상임을 git merge-base 로 확인했다. 기존 계획·할 일·돌아보기는 사용자가 직접 만든 소유자 계정에 귀속했다.

네 가지 결정이 과제의 요구를 그대로 만족시킨다

"로그아웃하면 이전 값이 안 통한다"를 만들려면 서버가 세션을 폐기할 수 있어야 한다.

직접 구현한 서버 세션

Auth.js 는 Credentials 를 쓰면 세션이 JWT 로 고정되어 폐기할 수 없다.
Supabase Auth 는 로그아웃 뒤에도 토큰이 만료 전까지 유효하다.

→ 로그아웃 = DB 행 삭제

bcrypt (cost 12)

계정마다 소금값을 자동 생성·포함한다. 순수 JS 라 서버리스에서 네이티브 빌드가 필요 없다.

→ 같은 비밀번호도 해시가 다름

불투명 난수 세션 토큰

쿠키에는 의미 없는 난수만 담고 DB 에는 SHA-256 해시만 남긴다. 서명키가 아예 존재하지 않는다.

→ DB 유출로도 도용 불가

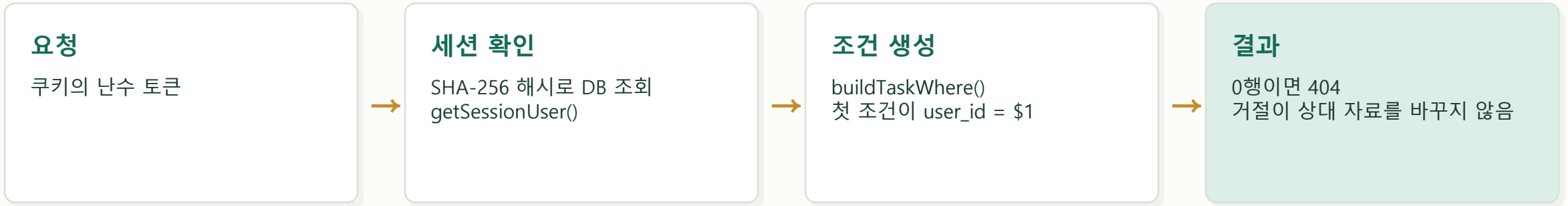
응답 DTO 화이트리스트

DB 행을 그대로 내보내지 않는다. 새 컬럼이 자동으로 실려 나가는 사고를 구조가 막는다.

→ user_id·deleted_at 미노출

사용자는 세션에서만 정해지고, 소유자 조건은 한곳에서 만든다

주소·헤더·요청 본문에서 사용자 ID 를 읽는 코드는 이 프로젝트에 존재하지 않는다.



왜 403 이 아니라 404 인가

- WHERE id = \$1 AND user_id = \$2 가 0행을 돌려주면 자연스럽게 404 가 된다.
- 403 은 "그 자료는 있지만 네 것이 아니다"를 알려 준다 — 존재 자체가 정보가 된다.
- 같은 WHERE 를 UPDATE·DELETE 에도 두었기 때문에, 거절된 요청은 상대 자료를 건드리지 못한다.
- 목록·검색·거르기·집계가 모두 `buildTaskWhere` 한 곳을 지나므로 라우트마다 조건을 빠뜨릴 자리가 없다.

자동 검증 결과 — 두 방향 모두: 읽기 404 · 수정 404 · 삭제 404 · 날짜 이동 404 · 상대 자료 불변 · 목록 유출 0건

공개 배포 주소에서 확인한 결과

일회성 계정으로 검증하고 증거를 남긴 뒤 계정과 자료를 정리했다.

검증 항목	결과
미로그인 자료 API	401
공개 첫 화면 · /tasks	선택 화면 200 · 자료 화면 307 → /login
중복 가입	409
같은 비밀번호의 두 저장값	서로 다른 bcrypt 해시 (cost 12)
틀린 비밀번호 · 없는 아이디	같은 문구 · 401
타 계정 읽기 · 수정 · 삭제	양방향 모두 404, 상대 자료 불변
타 계정 목록 유출	0건 (요청 본문의 사용자 필드는 무시)
로그아웃 · 비밀번호 변경 뒤 이전 세션	401
내 자료 내보내기	JSON 200 · 타 계정 유출 0건 · 내부 필드 미노출
계정 삭제	사용자 · 계획 · 할 일 0건, 이전 세션 401
자동 검사 · 타입 · 빌드 · 감사	28건 통과 · 통과 · 통과 · 취약점 0건
비밀값 스캔	로컬 · Git 전체 이력 0건

계획 규칙을 하나 바꾸고 전후를 같은 지표로 비교

질문: 계획한 시간과 실제로 쓴 시간의 차이를, 계획 규칙을 바꿔서 줄일 수 있는가?

지표 하루 시간 오차율 (%) = (그날 완료한 할 일의 실제 분 합 - 예상 분 합) ÷ 예상 분 합 × 100 · 소수 첫째 자리 반올림

일차	날짜	예상	실제	오차율
1일차	2026-08-29	3 분	4 분	+33.3 %
2일차	2026-08-30	62 분	4 분	-93.5 %
3일차	2026-08-31	4 분	4 분	0.0 %
4일차	2026-09-01	4 분	4 분	0.0 %
5일차	2026-09-02	8 분	4 분	-50.0 %

계획 규칙 변경

2026-08-31 10:30:55 (Asia/Seoul)

2일차 기록 뒤 · 3일차 기록(15:30:23) 앞

예상 시간 상한 60분 → 90분 하나만 변경

-30.1 %

변경 전 평균 (1·2일차)

-16.7 %

변경 후 평균 (3~5일차)

-22.0 %

5일 전체 평균

감추지 않은 것
개선의 대부분은 2일차 한 건(-93.5%)이 빠진 효과다. 2일차는 60분 상한에 맞추려고 62분으로 부풀려 잡았다가 4분에 끝난 날이라, 규칙 변경의 효과라기보다 그날의 어림 실패가 컸다. 하루 1건씩 5일뿐이므로 이 결론은 잠정이다.

화면 합계와 손으로 더한 값이 같은지 대조

돌아보기 화면은 완료일이 아니라 마감일로 거른다. 5일치 마감일이 8/31~9/4 라 기간을 9/4 까지 잡아야 5건이 모두 잡힌다.

플랜두씨

플래너 계획 할 일 돌아보기 내보내기 계정

test님 [로그아웃](#)

SEE

돌아보기

계획과 실제의 차이를 확인하고 다음 행동 한 줄을 정하세요.

100% 완료율

PERIOD

초회 기간

시작일

2026-08-29

→

종료일

2026-09-04

조회

SUMMARY

2026.08.29 - 2026.09.04

숫자를 누르면 근거 목록으로 이동합니다.

계획

5

마감이 기간 안인 할 일

완료

5

완료율 100%

지연

0

미완료·마감 지남

막힘

1

막힌 이유가 있는 기록

예상

81분

계획한 총 시간

실제

20분

기록한 총 시간

차이

-61분

실제 - 예상

NEXT PLAN

다음에 바꿀 한 가지

결과를 평가하는 데서 끝내지 말고 다음 계획에서 실행할 행동으로 바꾸

고칠 점

예: 시작 전에 방해 요소 하나 치우기

이 한 줄로 계획 만들기

T07-A17 · 공개 배포 돌아보기 (기간 2026.08.29~2026.09.04)

손 계산

예상 = 3 + 62 + 4 + 4 + 8 = 81
실제 = 4 + 4 + 4 + 4 + 4 = 20
차이 = 20 - 81 = -61

항목	화면	손
예상 분 합	81	81
실제 분 합	20	20
차이	-61	-61

세 항목 모두 일치

평균 오차율(-22.0%)은 이 화면에 없는 값이다.
화면은 예상·실제·차이 세 개만 보여 주므로
평균은 손 계산으로만 구했고 그 사실을 문서에 적었다.

공개 배포 앱 · Postman · 실제 DB 화면

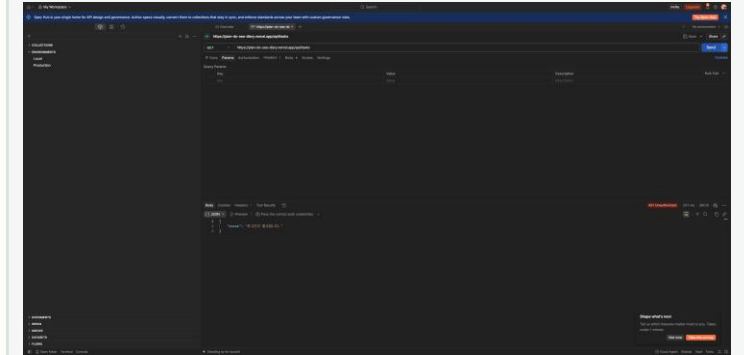
요약 화면이 아니라 실제로 동작하는 화면만 제출 증거로 쓴다. 비밀번호·쿠키·토큰은 모두 가렸다.



T07-E01 · 공개 시작 화면



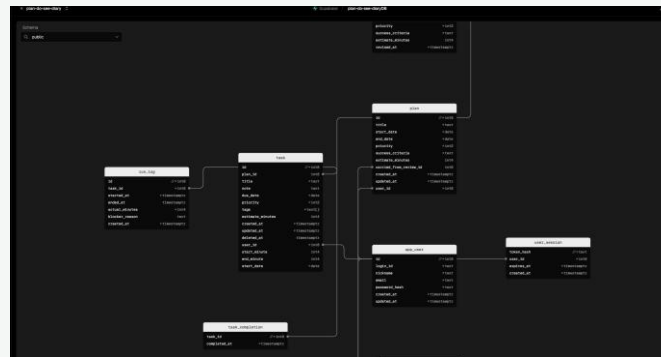
T07-E02 · 로그인 화면



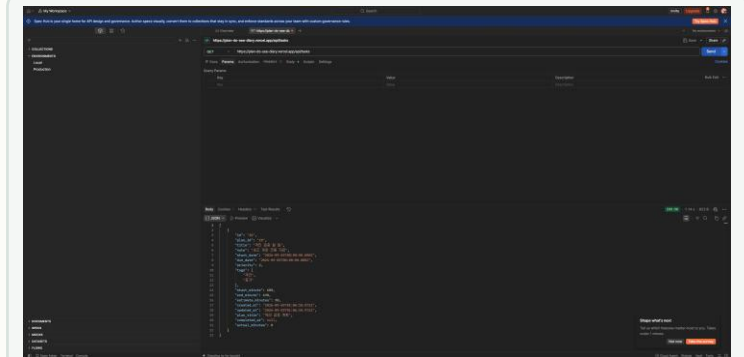
T07-A14 · 로그아웃 뒤 401



T07-A08 · 실제 DB: bcrypt·세션 해시



T07-A09 · 실제 8개 표 관계



T07-A22 · 목록에 본인 자료만

AI가 만든 것, 내가 정한 것, 그리고 남은 구멍

무엇을 못 막았는지까지 적어야 이 과제가 끝난다.

AI와 내 판단 3줄

- AI에게 맡긴 일 — 과제 6 코드 분석, 가입·로그인·서버 세션·사용자별 자료 차단 구현, DB 이전과 자동 검증, 문서 최신화.
- 내가 직접 판단한 일 — 과제 6을 지우지 않고 같은 저장소·배포·DB에서 이어가기로 정했고, 실제 계정 가입과 계획·할 일·실행 기록 입력은 내가 했다.
- AI 제안을 따르지 않은 일 — 새 DB로 분리하는 대안 대신, 과제 6 자료를 보존해 내 계정으로 귀속하는 방식을 택했다.

못 막은 것 (남은 제한)

- 로그인 시도 횟수 제한·계정 잠금·CAPTCHA 가 없다 — 무차별 대입에 취약하다.
- 비밀번호 찾기가 등록 정보 일치 방식이다. 이메일 소유 확인과 일회용 링크가 없다.
- 관리자용 세션 강제 종료와 감사 로그가 없다.

핵심 제출 범위인 가입 · 로그인 · 즉시 세션 폐기 · 사용자별 자료 차단은 구현하고 공개 배포 환경에서 검증했다.

비밀번호 규칙은 10자 이상 + 대문자·소문자·숫자·특수문자 각 1자 이상으로 두어, 시도 제한이 없는 상태에서 추측 난이도를 올렸다. 중복 확인은 화면 검사와 DB 유니크 인덱스 두 겹으로 두어 확인과 제출 사이에 남이 먼저 가입하는 경우까지 막았다.